

PROCEDURE DE DURCISSEMENT

Active Directory - jolan.ecoris

Audit PingCastle - Savoie Network

Domaine	jolan.ecoris
Score initial	90 / 100 (Critique)
Score final	35 / 100
Outil utilise	PingCastle 3.5.0.44
Auteur	Jolan - BTS SIO SISR

1. Présentation du projet

Score initial : 90/100 - Objectif : descendre sous 40/100

Ce document présente la démarche de durcissement de l'Active Directory jolan.ecoris dans le cadre du projet lab Savoie Network. Chaque correction est appliquée individuellement, suivie d'un nouveau scan PingCastle pour mesurer son impact sur le score.

L'outil PingCastle évalue la sécurité AD selon 4 catégories : Comptes Privileges, Anomalies, Objets Obsoletes et Relations de Confiance. Le score global correspond au score maximum parmi ces 4 catégories.

La première étape a été d'installer PingCastle sur PC-6
: <https://github.com/netwrix/pingcastle/releases/latest>

Ensuite extraire le fichier et lancer le premier scan.

Pour chaque nouveau scan à réaliser après modification, il suffit d'aller dans :

C:\Users\g.durieux\Downloads\PingCastle_3.5.0.44\PingCastle.exe

```
<GlobalScore>90</GlobalScore>
<StaleObjectsScore>36</StaleObjectsScore>
<PrivilegedGroupScore>90</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>85</AnomalyScore>
```

Indicators



Domain Risk Level: 90 / 100

It is the maximum score of the 4 indicators and one score cannot be higher than 100. The lower the better

[Compare with statistics](#)

[Privacy notice](#)



2. Corrections appliquees

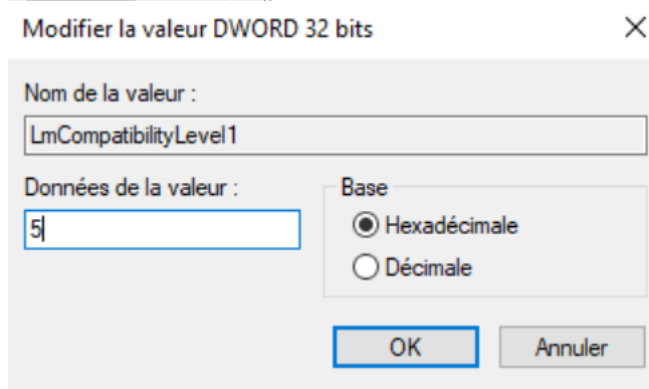
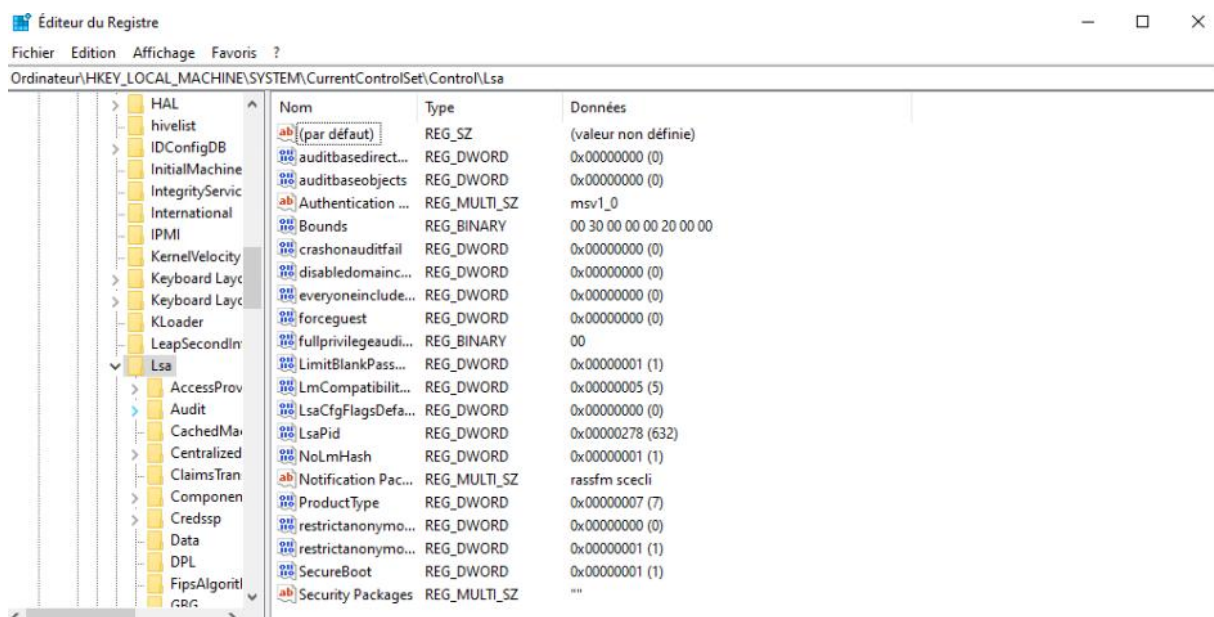
1. Desactivation de NTLMv1 et LM

Impact estime	Categorie	Machine
-15 pts (Objets obsoletes)	Stale Objects	AD-PRIV

Contexte

NTLMv1 et LM sont des protocoles d'authentification obsolètes vulnérables aux attaques pass-the-hash. Forcer NTLMv2 uniquement via le registre.

Modification apportées



Vérification

```
<GlobalScore>90</GlobalScore>
<StaleObjectsScore>21</StaleObjectsScore>
<PrivilegedGroupScore>90</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>85</AnomalyScore>
```

2. Activation de la Corbeille Active Directory

Impact estime	Catégorie	Machine
-10 pts (Comptes privilèges)	Privileged Accounts	AD-PRIV

Contexte

La corbeille

AD permet de restaurer des objets supprimés accidentellement sans restaurer une sauvegarde complète.

Modification



Après manipulation dans le Centre d'administration Active Directory l'option est activé.

Verification

```
<GlobalScore>85</GlobalScore>  
<StaleObjectsScore>21</StaleObjectsScore>  
<PrivilegedGroupScore>80</PrivilegedGroupScore>  
<TrustScore>0</TrustScore>  
<AnomalyScore>85</AnomalyScore>
```

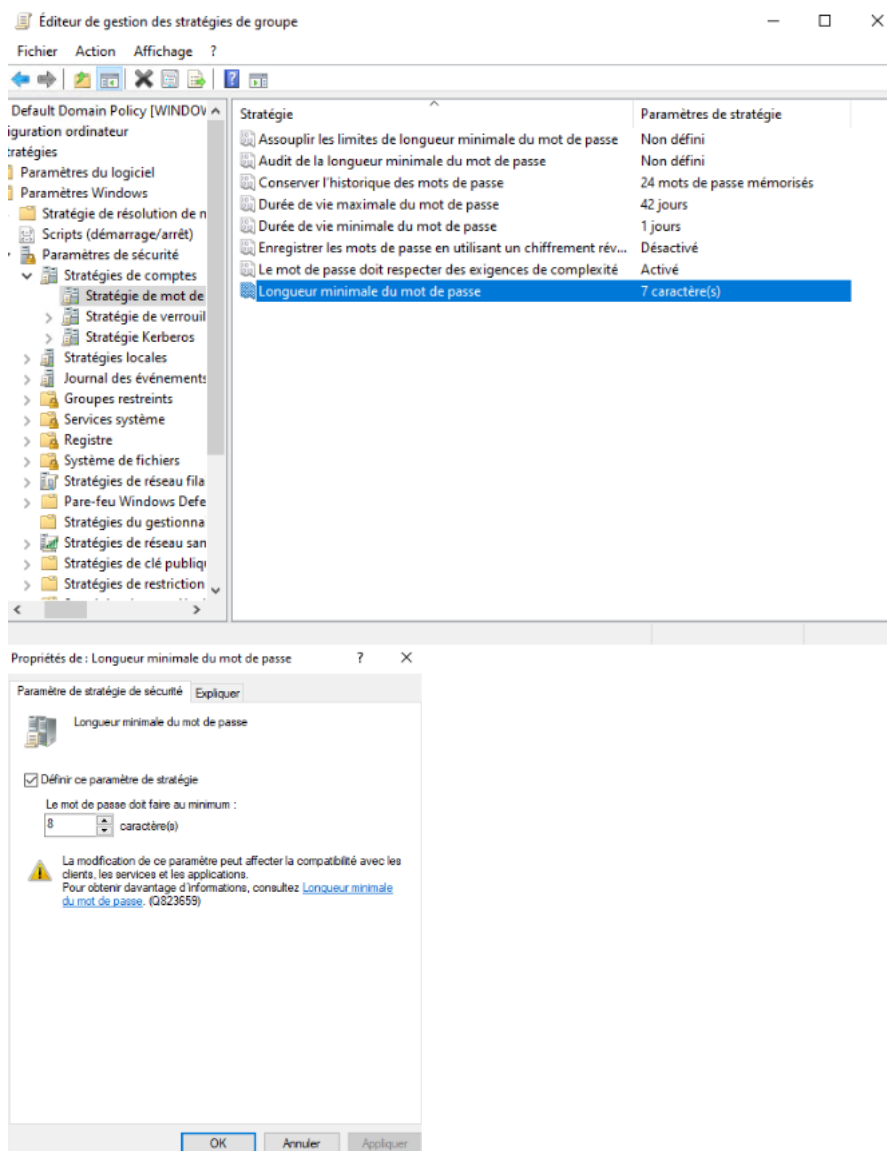
3. Longueur minimale du mot de passe portée a 8 caractères

Impact estime	Categorie	Machine
-10 pts (Anomalies)	Anomalies	AD-PRIV

Contexte

La politique par défaut autorise des mots de passe de 7 caracteres.
Les recommandations ANSSI imposent 8 caracteres minimum.

Modification



Vérification

```
<GlobalScore>80</GlobalScore>
<StaleObjectsScore>21</StaleObjectsScore>
<PrivilegedGroupScore>80</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>75</AnomalyScore>
```

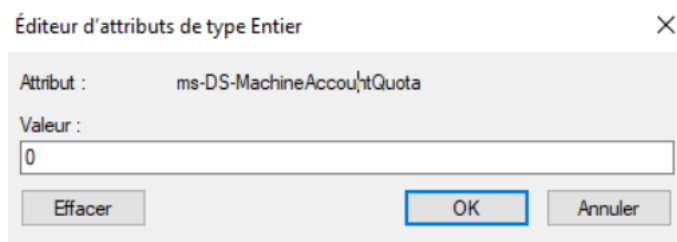
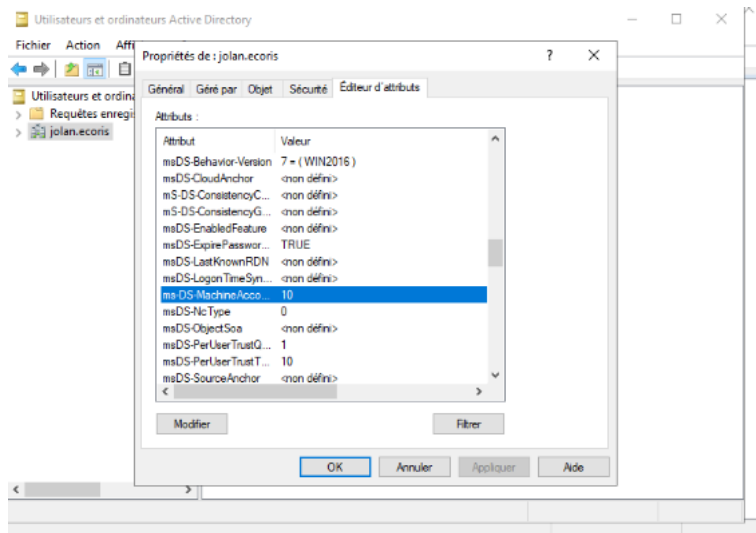
4. Reduction du quota MachineAccountQuota a 0

Impact estime	Categorie	Machine
-10 pts (Objets obsoletes)	Stale Objects	AD-PRIV

Contexte

Par défaut tout utilisateur peut ajouter jusqu'à 10 machines au domaine. Seuls les administrateurs doivent pouvoir joindre des machines.

Modification



Vérification

```
<GlobalScore>80</GlobalScore>
<StaleObjectsScore>11</StaleObjectsScore>
<PrivilegedGroupScore>80</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>75</AnomalyScore>
```

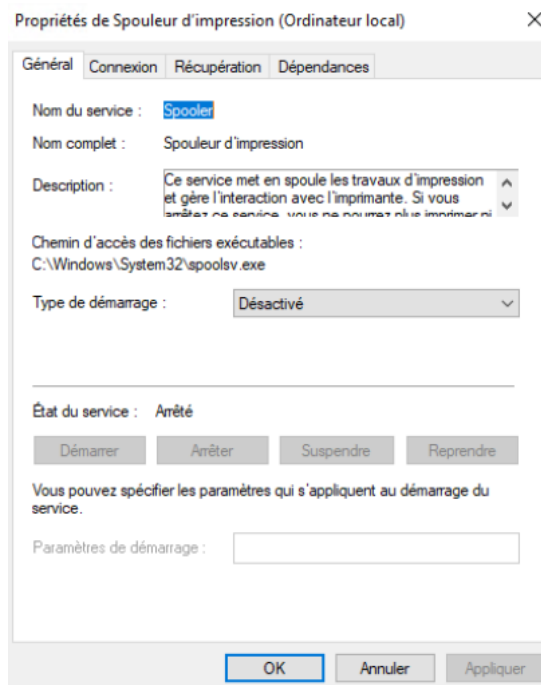
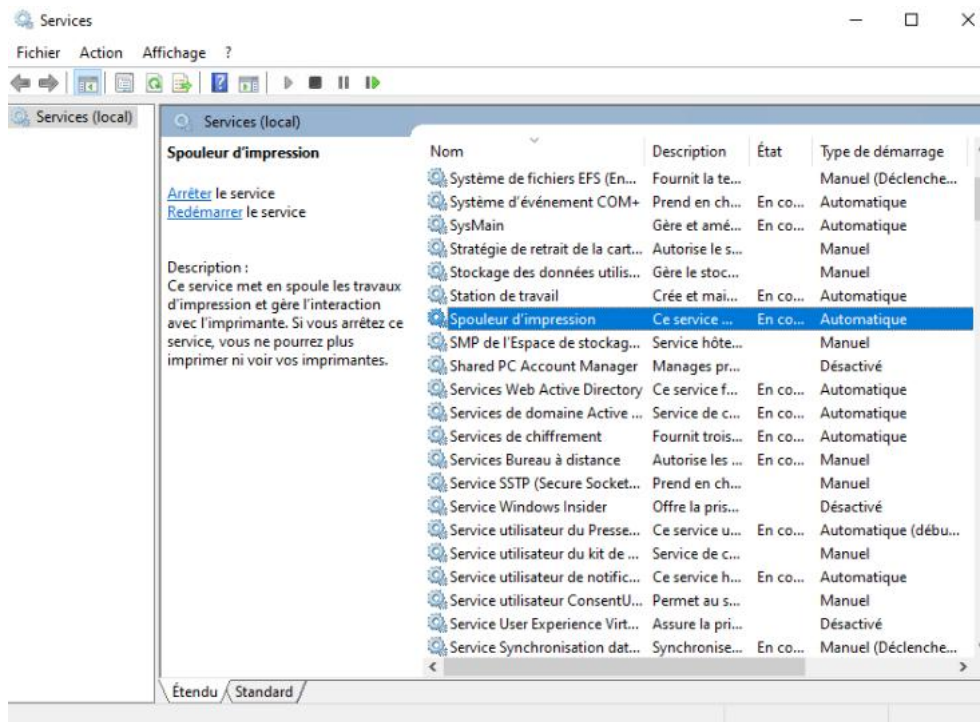
5. Désactivation du service Spooler sur le DC

Impact estime	Catégorie	Machine
-10 pts (Anomalies)	Anomalies	AD-PRIV

Contexte

Le service Print Spooler expose le DC a la vulnérabilité PrintNightmare (CVE-2021-34527).
Il n'a aucune utilité sur un DC.

Modification



Vérification

```

<GlobalScore>80</GlobalScore>
<StaleObjectsScore>11</StaleObjectsScore>
<PrivilegedGroupScore>80</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>55</AnomalyScore>

```

6. Activation de l'audit des controleurs de domaine

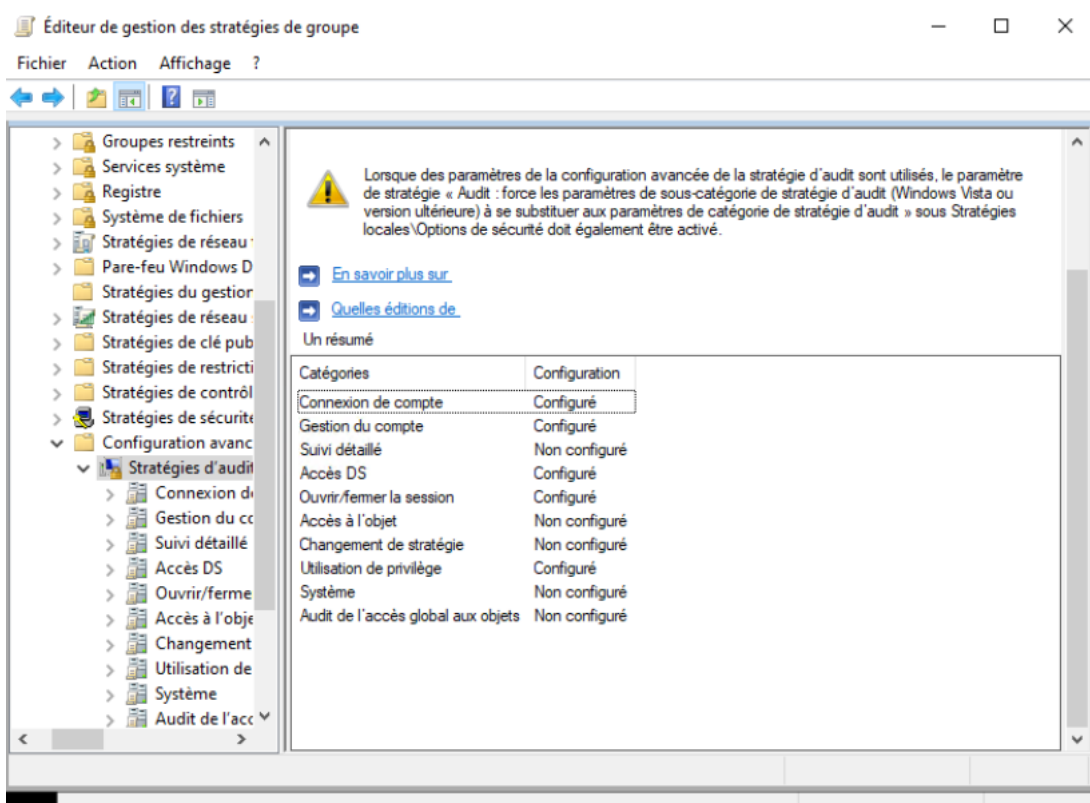
Impact estime	Categorie	Machine
-10 pts (Anomalies)	Anomalies	AD-PRIV

Contexte

Les evenements de securite critiques ne sont pas journalises. L'audit avantee permet de detecter les activites malveillantes.

Modification

Configuration des catégories Connexion de compte, gestion du compte, accès DS, Ouvrir/fermer la session et utilisation du privilège, pour chaque sous catégories, cocher Succès et Echec.



Vérification

```
<GlobalScore>80</GlobalScore>
<StaleObjectsScore>11</StaleObjectsScore>
<PrivilegedGroupScore>80</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>55</AnomalyScore>
```

On peut voir que malgré l'utilité de cette modification, PingCastle ne prends pas en compte la modification dans son analyse du Domaine.

7. Flag compte sensible et non delegable sur les admins

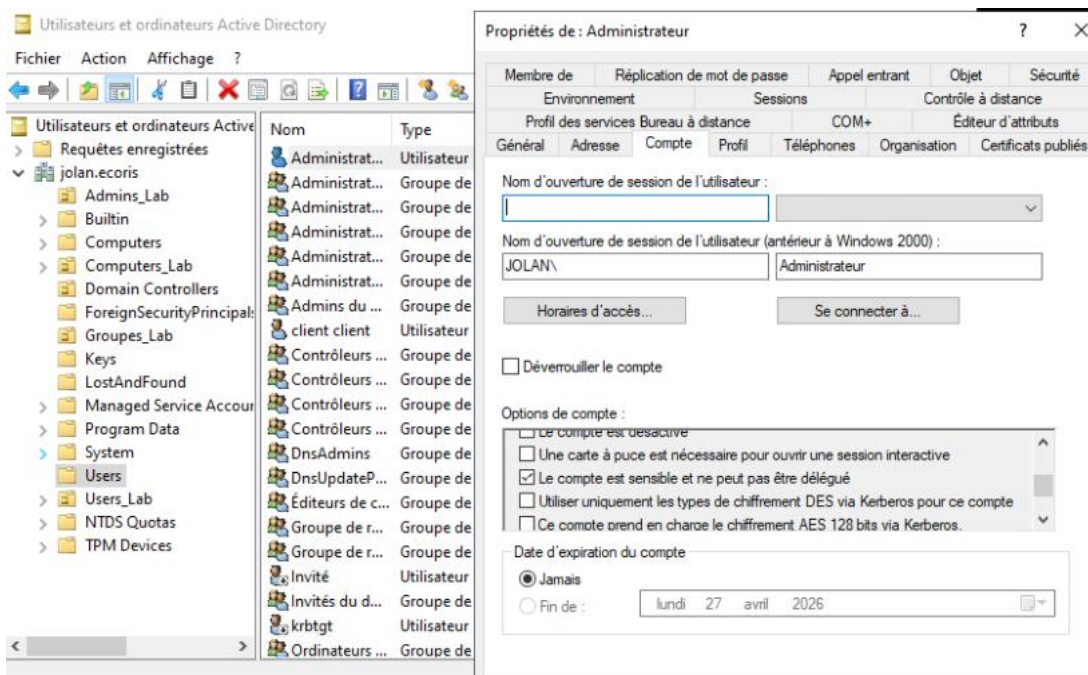
Impact estime	Categorie	Machine
-20 pts (Comptes privileges)	Privileged Accounts	AD-PRIV

Contexte

Les comptes admin peuvent etre delegates, ce qui represente un risque de compromission. Ce flag empeche la delegation Kerberos sur ces comptes.

Modification

Modification sur le compte Administrateur et client client.



Vérification

```
<GlobalScore>60</GlobalScore>
<StaleObjectsScore>11</StaleObjectsScore>
<PrivilegedGroupScore>60</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>55</AnomalyScore>
```

8. Ajout des admins au groupe Protected Users

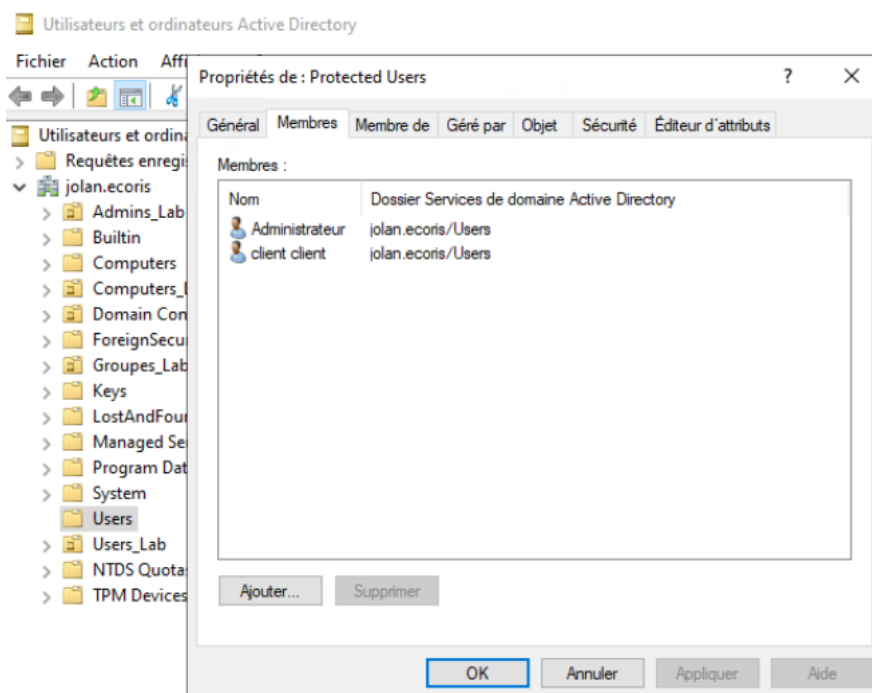
Impact estime	Categorie	Machine
-10 pts (Comptes privileges)	Privileged Accounts	AD-PRIV

Contexte

Protected Users desactive NTLM, DES et RC4, et empeche la mise en cache des credentials. Tous les admins doivent en faire partie.

Modification

Ajoute des users Administrateur et client client au groupe Protected Users.



Vérification

```
<GlobalScore>50</GlobalScore>
<StaleObjectsScore>11</StaleObjectsScore>
<PrivilegedGroupScore>45</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>50</AnomalyScore>
```

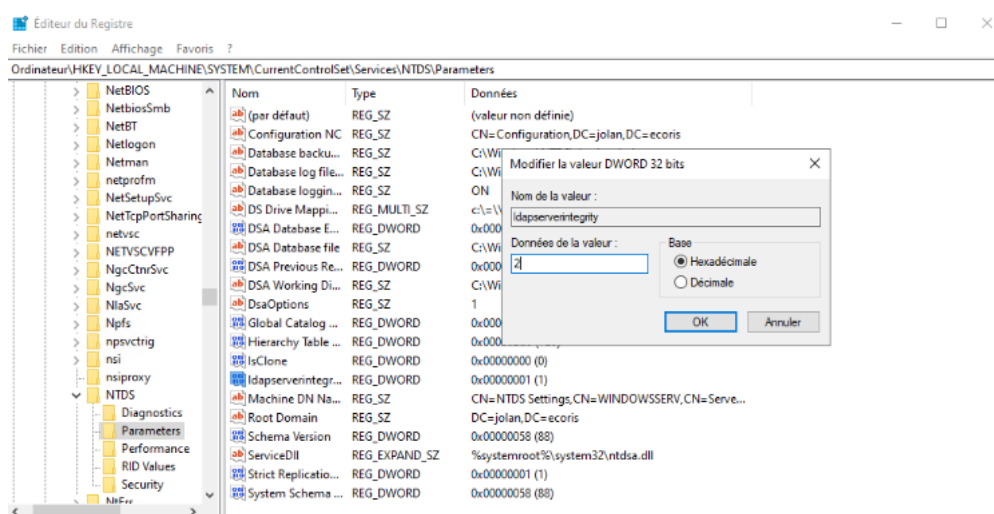
9. Activation de la signature LDAP

Impact estime	Categorie	Machine
-5 pts (Anomalies)	Anomalies	AD-PRIV

Contexte

Les authentifications LDAP sans signature sont vulnérables aux attaques man-in-the-middle. La signature garantit l'intégrité des communications.

Modification



Vérification

```
<GlobalScore>50</GlobalScore>  
<StaleObjectsScore>11</StaleObjectsScore>  
<PrivilegedGroupScore>45</PrivilegedGroupScore>  
<TrustScore>0</TrustScore>  
<AnomalyScore>50</AnomalyScore>
```

On peut voir que malgré l'utilité de cette modification, PingCastle ne prends pas en compte la modification dans son analyse du Domaine.

10. Vidage du groupe Schema Admins

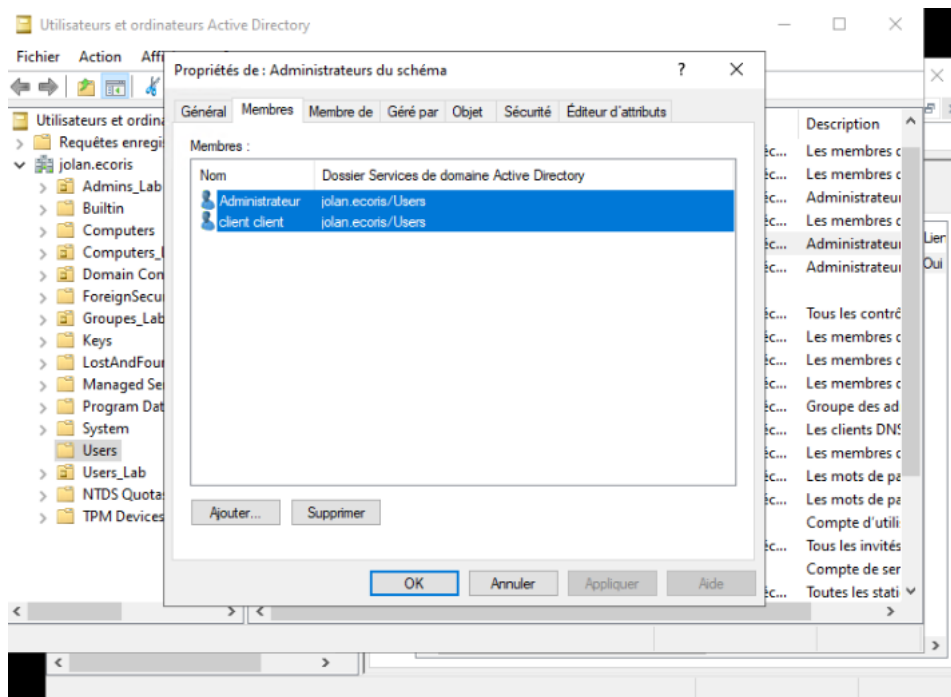
Impact estime	Categorie	Machine
-10 pts (Comptes privileges)	Privileged Accounts	AD-PRIV

Contexte

Schema Admins ne doit contenir des membres que pendant les operations de modification du schema. Le laisser peuple est un risque irreversible.

Modification

Suppression des deux comptes présents.



Vérification

```
<GlobalScore>50</GlobalScore>
<StaleObjectsScore>11</StaleObjectsScore>
<PrivilegedGroupScore>35</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>50</AnomalyScore>
```

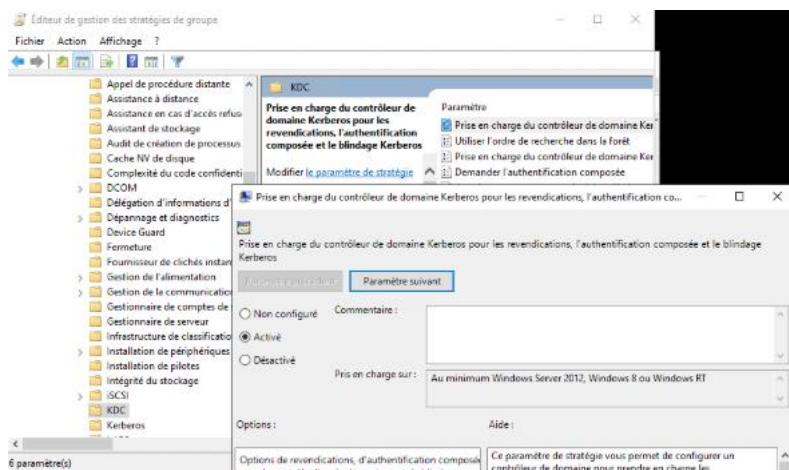
11. Activation de Kerberos Armoring (FAST)

Impact estime	Categorie	Machine
Amelioration (Objets obsoletes)	Stale Objects	AD-PRIV

Contexte

Kerberos Armoring ajoute un tunnel chiffre protecteur contre les attaques AS-REP Roasting et les attaques sur la pre-authentification Kerberos.

Modification



Verification

```
<GlobalScore>50</GlobalScore>
<StaleObjectsScore>11</StaleObjectsScore>
<PrivilegedGroupScore>35</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>50</AnomalyScore>
```

12. Sauvegarde de l'état du système AD

Impact estime	Categorie	Machine
-15 pts	Anomalies rule	AD-PRIV

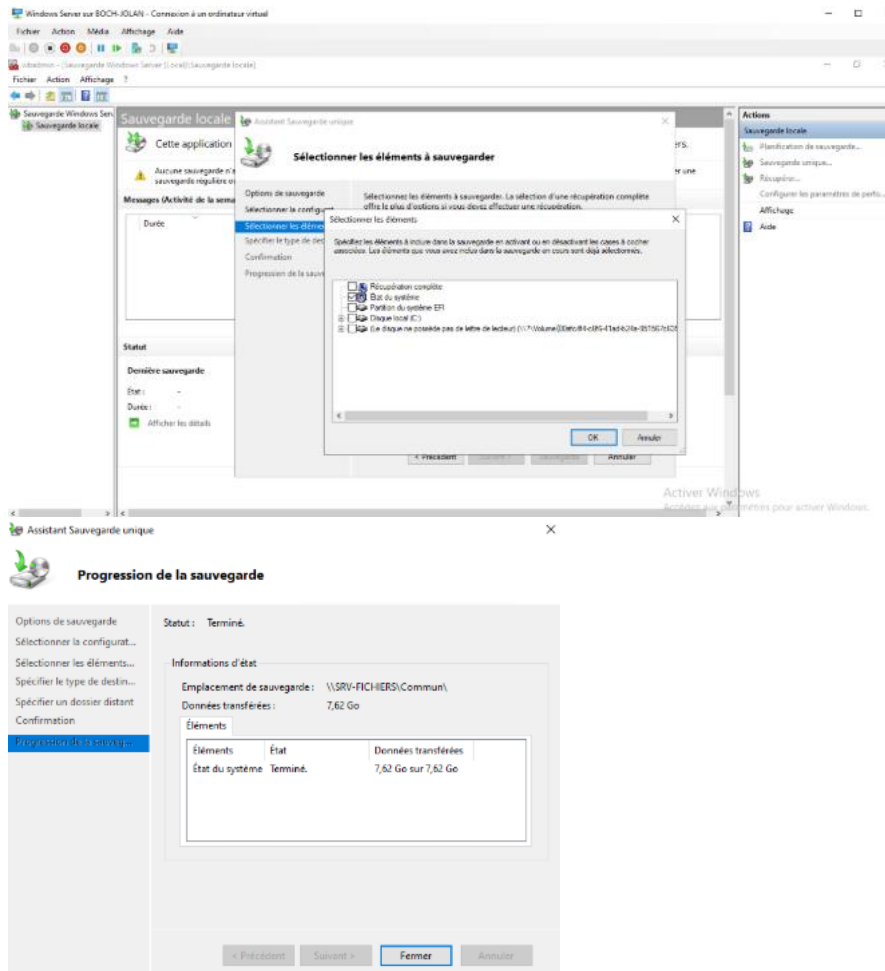
Contexte

PingCastle détecte que la dernière sauvegarde Active Directory remonte à 118 jours. En cas de corruption, l'absence de sauvegarde récente rend la restauration impossible ou très complexe.

Cette correction utilise la fonctionnalité native Sauvegarde Windows Serveur directement sur AD-PRIV sans infrastructure de backup dédiée.

Modification

Ajout de la fonctionnalité Sauvegarde Windows Serveur dans le gestionnaire de serveur : **Gestionnaire de serveur** → **Gérer** → **Ajouter des rôles et fonctionnalités**



Vérification

```
<GlobalScore>35</GlobalScore>
<StaleObjectsScore>11</StaleObjectsScore>
<PrivilegedGroupScore>35</PrivilegedGroupScore>
<TrustScore>0</TrustScore>
<AnomalyScore>35</AnomalyScore>
```

13. Installation et configuration de LAPS

Impact estime	Catégorie	Machine
-15 pts	Anomalies rule	AD-PRIV

Contexte

Sans LAPS, les postes du domaine partagent généralement le même mot de passe administrateur local. Si un attaquant compromet un poste et récupère ce mot de passe, il peut se déplacer latéralement sur tout le parc. LAPS génère un mot de passe aléatoire unique par machine, le stocke dans l'Active Directory et le renouvelle automatiquement tous les 30 jours. Seuls les comptes autorisés peuvent lire ces mots de passe. Sur jolan.ecoris, LAPS a été déployé via GPO sur l'OU Computers_Lab et validé sur PC-6.

Modification

Installation de LAPS sur Windows Server avec les outils Fat Client UI, Powershell module et GPO Editor templates.

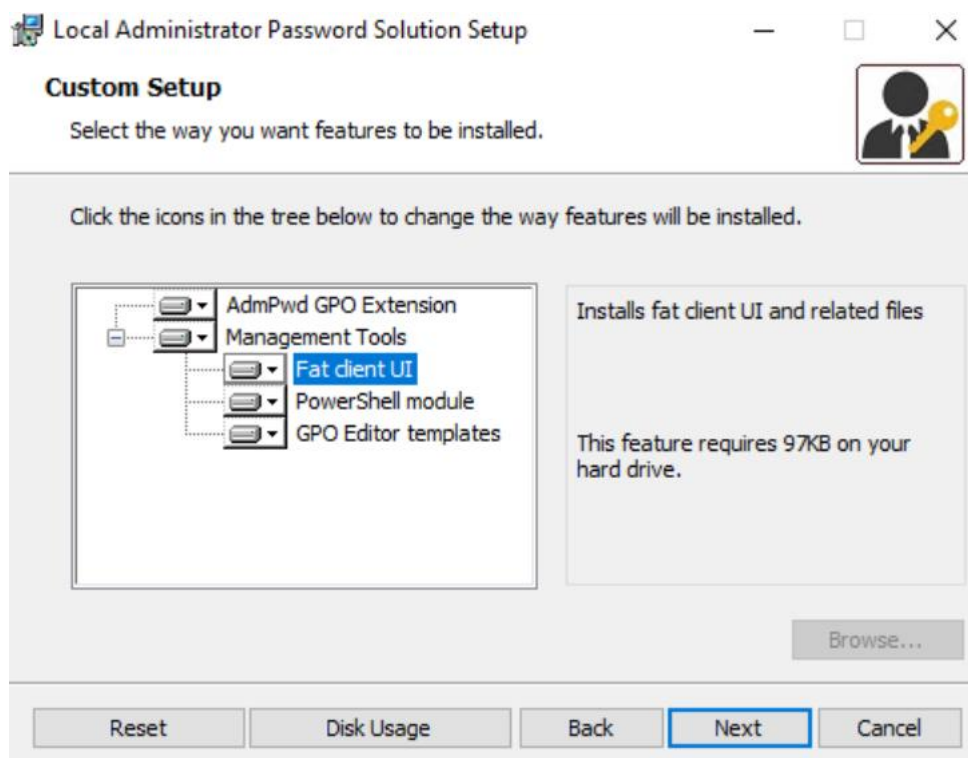


Schéma AD étendue ci-dessous :

```
PS C:\Users\Administrateur> Import-Module AdmPwd.PS
>> Update-AdmPwdADSchema

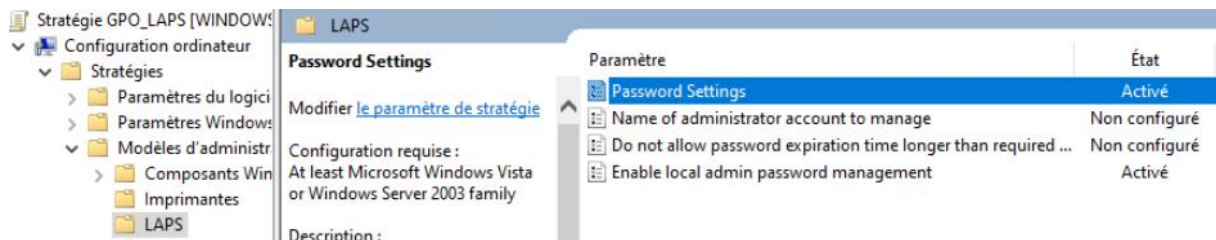
Operation      DistinguishedName      Status
-----
AddSchemaAttribute cn=ms-Mcs-AdmPwdExpirationTime,CN=Schema,CN=Configuration,DC=j... Success
AddSchemaAttribute cn=ms-Mcs-AdmPwd,CN=Schema,CN=Configuration,DC=jolan,DC=ecoris Success
ModifySchemaClass cn=computer,CN=Schema,CN=Configuration,DC=jolan,DC=ecoris Success
```


Permissions déléguées sur Computers_Lab :

```
PS C:\Users\Administrateur> Set-AdmPwdComputerSelfPermission -OrgUnit "Computers_Lab"
```

Name	DistinguishedName	Status
Computers_Lab	OU=Computers_Lab,DC=jolan,DC=ecoris	Delegated

Création de la GPO GPO_LABS liée à Computers_Lab avec les paramètres Password Settings et Enable local admin password management :



Installation de l'agent sur PC-6 sans les outils de management.

Vérification depuis Windows Server si les modifications sont opérationnelles :

```
PS C:\Users\Administrateur> Get-AdmPwdPassword -ComputerName "DESKTOP-L110E49"
```

ComputerName	DistinguishedName	Password	ExpirationTimestamp
DESKTOP-L110E49	CN=DESKTOP-L110E49,OU=Postes,OU=Computers_...	1+s\$R0nKPJ80I2	28/04/2026 16:08:22

Vérification

```
:GlobalScore>35</GlobalScore>  
:StaleObjectsScore>11</StaleObjectsScore>  
:PrivilegedGroupScore>35</PrivilegedGroupScore>  
:TrustScore>0</TrustScore>  
:AnomalyScore>20</AnomalyScore>
```

4. Dashboard courbe d'évolution

Création d'un Dashboard d'évolution du score, solution fournit par :

<https://github.com/leobouard/PingCastleDashboard>

Commandes utilisées :

Install-Module PSWriteHTML -Force

cd "C:\Users\g.durieux\Downloads\PingCastle_3.5.0.44"

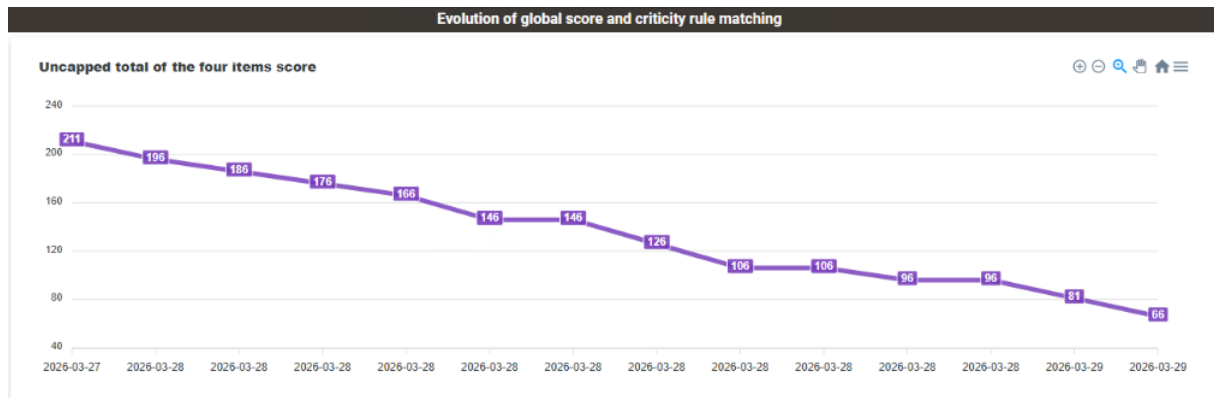
Invoke-WebRequest -

Uri:aeazeeaz "https://raw.githubusercontent.com/leobouard/PingCastleDashboard/main/PingCastleDashboard.ps1" -OutFile "PingCastleDashboard.ps1"

.\PingCastleDashboard.ps1 -XmlFolder "C:\Users\g.durieux\Downloads\PingCastle_3.5.0.44"

Sélection de tous les fichiers .XML généré au fur et à mesure que j'ai stocké et numéroté.

Voici le Dashboard :



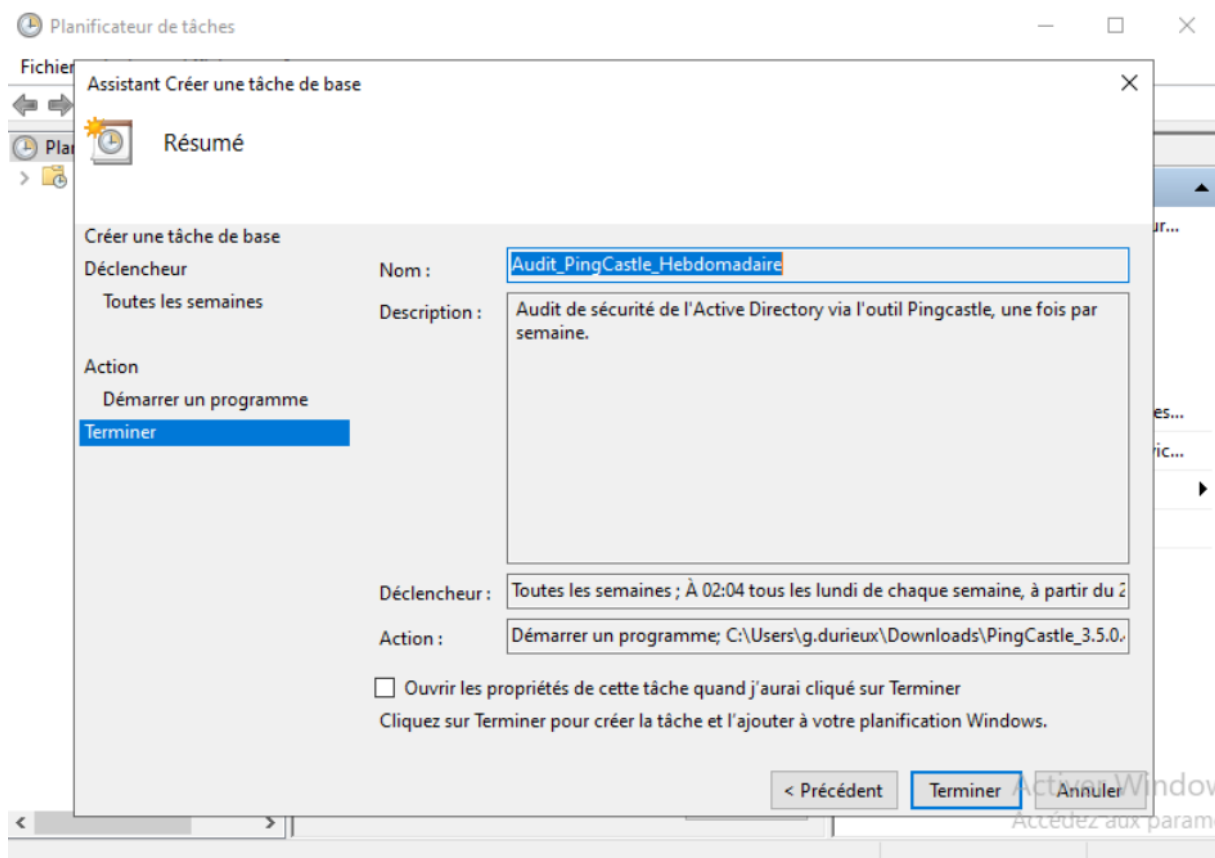
On peut y voir le cumule des scores des 4 catégories en fonction du temps.

La courbe décroît clairement synonyme d'une bonne utilisation de notre part de l'outil PingCastle.

5. Automatisation - Tache planifiée

Une solution de sécurité est de planifier chaque semaine une analyse afin de garder un Active Directory sain et organiser.

Configuration de la tâche



La tâche est bien en place et fonctionne parfaitement.

6. conclusion :

Ce projet d'audit et de durcissement de l'Active Directory a permis de réduire significativement le score de risque PingCastle de **90/100 à 35/100**, soit une baisse de 55 en appliquant 13 mesures correctives ciblées.

Certaines corrections comme l'audit des contrôleurs de domaine et la signature LDAP n'ont pas eu d'impact immédiat sur le score PingCastle mais améliorent tout de même la sécurité de l'infrastructure, cela illustre les limites de tout outil d'audit automatisé.

La mise en place d'une tâche planifiée hebdomadaire et du Dashboard PingCastleDashboard permet désormais un suivi continu de la posture de sécurité du domaine, avec une visualisation claire de la progression dans le temps.

La possibilité d'une évolution faisant baisser le score de 35/100 est toujours possible et envisageable.